

NARRATIVA EXPLICATIVA: LA ENCUESTA DE CIBERSEGURIDAD COMO ACTO PROPOSITIVO

Sobre el Tono Irónico, Literario y la Construcción de Madurez

Autor: Consorcio de Científicos de Datos y Estrategas de Ciberseguridad

Fecha: Enero 2026 | **Ámbito:** España e Internacional

Propósito: Explicar la filosofía, diseño e intención de la Encuesta Integral de Ciberseguridad

PRÓLOGO: ¿POR QUÉ OTRA ENCUESTA?

En el panorama actual de ciberseguridad, hemos alcanzado un punto de saturación casi cómico: existen tantos frameworks, modelos de madurez y metodologías de evaluación que uno podría pasarse dos vidas estudiando todos ellos sin jamás **hacer nada útil**.

SAMM. NIST. ISO 27001. CIS Controls. BSIMM. CMMC. ENS. NIS2. CRA. DORA. GDPR. Y lista y va.

Es como si la industria de ciberseguridad hubiera confundido evaluar con *nombrar bien*. Como si dijeran: "¿Seguridad débil? Perfecto, necesita un **Assessment Framework** nuevo. Vamos a crear 90 preguntas, asignarles números del 0 al 3, y llamarlo 'Madurez'."

Pero aquí está el quid, donde reside la verdad incómoda: la mayoría de evaluaciones se quedan en el diagnóstico.

Sí, diagnostican. Perfecto. Y luego... ¿qué?

ACTO I: FICCIÓN Y REALIDAD EN SEGURIDAD

La Ilusión de la Encuesta Convencional

Imaginemos una escena típica en una organización mediana española. Es martes por la mañana. El CISO ha enviado un correo: "Necesitamos hacer una evaluación SAMM."

Los equipos reciben un formulario, a menudo de Google Forms con aquella fuente verde apagada que transmite tanto entusiasmo como una factura de electricidad. **90 preguntas. 45 minutos. "Por favor, complétalo para el viernes."**

Luego ocurre algo magnífico: **cada rol responde desde su propia isla cognitiva.**

- El Arquitecto piensa en decisiones estratégicas y diseños ecosistemáticos.
- El Developer piensa: "¿Tenemos SAST? Creo que sí. ¿O fue hace seis meses?"
- El QA piensa: "¡Claro que hacemos testing! Aunque el equipo de Desarrollo rara vez escucha nuestros hallazgos."
- Operations piensa: "Monitoreamos todo. Somos los campeones silenciosos."
- Gobernanza piensa: "¿Requisitos regulatorios? Eso suena importante. Déjame consultar mi documento de compliance."

Y aquí está la magia invisible: Cada uno responde "3" donde los demás responden "1". No es mentira. Es **realidades paralelas**.

Luego alguien (generalmente un analista junior, pobre alma) descarga las respuestas en Excel, calcula promedios, y genera un gráfico que parece haber sido diseñado por alguien que odiaba el arte, la claridad y la esperanza humana simultáneamente.

"Promedio global SAMM: 1.44. Gobernanza: 1.4. Diseño: 1.2. ¿Qué significa esto?"

Nadie lo sabe. Pero suena importante. Se presenta a la Junta Directiva. Todos asienten. Algunos toman café. Se cierran sesiones. Se olvida.

Esto es, honestamente, lo que la mayoría de organizaciones llama "evaluación de madurez".

La Grieta en el Espejo

Pero nuestra Encuesta Integral de Ciberseguridad se niega a ser cómplice de esta ilusión.

¿Por qué?

Porque reconoce algo fundamental: **las discrepancias entre roles no son errores en la encuesta. Son datos. Son fricciones reales. Son oportunidades.**

Cuando un Developer dice "Implementation está en L1.8" y un Arquitecto dice "está en L1.2", no significa que uno miente. Significa que **la realidad de "construcción segura" es radicalmente diferente** dependiendo de dónde te sientes en la organización.

El Developer ve su CI/CD con gates de seguridad básicos. Para él, eso es "avanzado comparado a hace 3 años."

El Arquitecto *sabe* que esos gates no capturan vulnerabilidades lógicas, supply chain risks, o problemas de integración. Para él, es apenas nivel 1.2.

Y ambos tienen razón.

Esta es la grieta donde nuestra Encuesta se diferencia.

ACTO II: FILOSOFÍA DE DISEÑO

Principio 1: No Queremos Verdad. Queremos Verdades Interconectadas.

La encuesta NO persigue la ilusión de una "puntuación correcta".

En cambio, busca mapear el **espacio de perspectivas** de tu organización.

Hace una pregunta en 90 direcciones diferentes. Invita a 8-13 personas con roles distintos a responder cada una. **Y luego mira dónde divergen.**

Cuando divergen *mucho*, eso significa: "Aquí hay comunicación rota. Aquí hay silos. Aquí hay oportunidad de alineación."

Cuando convergen, significa: "Este concepto está claro en toda la organización. Puedes confiar en este baseline."

Es como usar una encuesta para hacer un escáner de coherencia organizacional, no solo de "madurez".

Principio 2: Las Métricas No Son Castigo. Son Conversación.

Cada pregunta está diseñada con una intención subyacente, raramente explícita:

Pregunta: "¿Qué porcentaje de threat models documentados existen?"

Intención oculta: ¿Es threat modeling algo *real* y *habitual* en tu organización, o es un ritual que alguien inventó para parecer sofisticado?"

Pregunta: "¿Cuál es el tiempo promedio para detectar un incidente?"

Intención oculta: ¿Tienes visibilidad? ¿Estás midiendo? ¿O es magia negra y rezos?"

Pregunta (meta): "¿Cuál es tu nivel de confianza en estas respuestas?"

Intención oculta: "Sabemos que es difícil. Y está bien no saber. De hecho, 'no sé' es información valiosa."

La encuesta no te juzga. **Te pregunta. Y escucha cómo diferencias roles* responden.**

Principio 3: Irónica es la Mejor Epistemología Empresarial.

He aquí una verdad incómoda: la mayoría de organizaciones practican ciberseguridad mediante **afirmaciones teatrales**.

"Somos GDPR compliant." (*Se asumen que lo eres, pero ¿lo verificaste con especialista? Probablemente no.*)

"Hacemos security testing." (*¿Sí? ¿Cuántas vulnerabilidades encontraste el mes pasado? ¿Alguna reparada antes de producción?*)

"Tenemos incident response." (*Claro. Respondemos por instinto. Eso cuenta.*)

La ironía, entonces, es la **postura epistemológica correcta** en ciberseguridad empresarial.

No como sarcasmo, sino como **observación lúcida de la distancia entre proclama y realidad**.

Nuestra encuesta **invita la ironía como herramienta cognitiva**. No para ser burlona (aunque ocasionalmente lo es), sino para permitir que digas:

"Sí, respondí Nivel 3 en Policy Compliance. Pero, siendo honestos, es más bien un Nivel 2.1. Si te soy completamente sincero, es Nivel 1.8. Porque el 30% de nuestra organización no conoce la política."

La ironía crea espacio para la honestidad.

ACTO III: ESTRUCTURA Y ARQUITECTURA NARRATIVA

¿Por Qué 90 Preguntas? ¿Por Qué Ese Número Exacto?

SAMM v2 tiene 15 prácticas de seguridad, con 2 streams cada una (30 total), y evaluación en 3 niveles de madurez. Eso genera naturalmente ~90 preguntas de evaluación.

Pero hay algo más profundo aquí.

90 preguntas es el número mágico donde:

- Pocos (< 5) y obtienes sesgos; muchos (> 150) y la gente se aburre (y miente).
- 90 requiere esfuerzo suficiente para que realmente reflexione.
- 90 es suficiente para capturar heterogeneidad sin ser exhaustivo.

Es como el Goldilocks de las encuestas de ciberseguridad. No demasiado caliente. No demasiado frío.

Justo lo correcto para generar datos pensados.

¿Por Qué 5 Módulos Principales (SAMM), Más 3 Adicionales (VA, SIEM, Training)?

SAMM cubre **cómo construyes, verificas y operas software de forma segura**.

Pero ciberseguridad empresarial no es solo software. Es también:

1. Vulnerabilidades: ¿Cómo identificas y priorizas riesgos? (Análisis de Vulnerabilidades, Penetration Testing)
2. Detección y Respuesta: ¿Cómo ves lo que ocurre cuando se rompe? (SIEM)
3. Factor Humano: ¿Son las personas parte de tu defensa o tu debilidad? (Capacitación)

Por eso extendemos SAMM para crear un **marco holístico de ciberseguridad** que incluya:

- Gobernanza y Estrategia
- Desarrollo Seguro (SAMM core)
- Vulnerabilidad y Validación
- Operaciones y Detección
- Capacitación y Cultura

Es como cambiar de mirar solo el código a mirar el código + infraestructura + personas + procesos.

ACTO IV: LENGUAJE Y ESTILO

¿Por Qué Este Tono Específico?

La encuesta utiliza un tono **irónico, literario y propositivo** por razones muy deliberadas:

Irónico

Propósito: Reducir defensividad.

La mayoría de las preguntas de ciberseguridad suenan como acusaciones.

"¿Implementó threat modeling? [Respuesta implícita: Si dices que no, eres incompetente. Si dices que sí, probablemente mientes.]"

Cuando introduces ironía, cambias la dinámica:

"Así que, hablemos de threat modeling. En una escala del 0 (no existe) al 4 (es como respirar), ¿dónde estaría tu organización? *[Spoiler: Nadie llega a 4. Y está bien. Nadie llega a 4.]*"

La ironía crea espacio psicológico para la verdad.

Literario

Propósito: Estimular reflexión más profunda que respuestas mecánicas.

Una pregunta literaria no es solo una pregunta. Es una **invitación a narración**.

"¿Cuándo fue la última vez que alguien en tu equipo se detuvo para preguntarse: '¿Realmente sabemos si nuestra arquitectura es segura? ¿O simplemente esperamos que lo sea?'"

Esta pregunta NO tiene opción de respuesta Likert (1-5). Pero su presencia *moldea* cómo se responden las otras.

Crea un **meta-contexto narrativo** donde la encuesta no es interrogatorio sino conversación.

Propositivo

Propósito: Orientar hacia acción, no hacia resignación.

Al final de cada módulo, la encuesta no dice: "Eres débil en Diseño. Qué mal."

Dice: "Diseño es donde está la oportunidad. Aquí es donde invertir genera máximo retorno. Aquí es donde diferenciarte de competidores."

Transforma brechas en oportunidades. Convierte debilidades en focos.

ACTO V: LOS ÍTEMS ESPECÍFICOS DE LA ENCUESTA

Modulo 1: Demográficos (La Metáfora del Territorio)

Las preguntas iniciales sobre sector, tamaño, jurisdicción, rol y antigüedad no son administrativas.

Son **cartografía**.

Mapean el territorio donde ocurre ciberseguridad. Porque la madurez de "un banco español" es diferente a la de "una startup MadTech en Barcelona" es diferente a la de "administración pública".

No por mejor/peor, sino por **contexto diferente, presiones diferentes, incentivos diferentes**.

Al capturar territorio, la encuesta te permite **compararte con pares verdaderos**.

No: "¿Cómo estoy vs. promedio global?"

Sino: "¿Cómo estoy vs. otros bancos españoles de ~400 personas en Madrid?"

Modulo 2: Gobernanza (La Conversación Incómoda)

Gobernanza es donde muchas evaluaciones se vuelven incómodas porque requiere que hagas preguntas sobre **liderazgo**.

"¿Existe estrategia documentada de seguridad?"

La mayoría de CISOs quiere decir: "Sí, tengo 200 slides en PowerPoint que no he actualizado desde 2022 y que viven en una carpeta de SharePoint que nadie visita."

La encuesta no te pide eso. Te pide reflexionar: **¿Existe? ¿Está comunicada? ¿Se mide?**

Y si la respuesta es "bueno, medio sí", eso es **información valiosa**.

Porque significa que probablemente el problema no es "falta de estrategia" sino "falta de comunicación de estrategia". Dos problemas muy diferentes.

Módulo 3: Diseño (El Acto de Anticipación)

"Threat modeling" es la pregunta arquitectónica central en Diseño.

¿Por qué?

Porque es el punto donde anticipas. Donde dices: "¿Qué podría salir mal? ¿Cómo atacarían esto?"

Una organización sin threat modeling es como un arquitecto que construye un puente sin preguntarse "¿Y si llueve mucho?"

La encuesta te pide que reflexiones: ¿hacemos anticipación sistemática o esperamos que los Developers adivinen?

Módulo 4: Implementación (El Trabajo Real)

Implementation es donde el Software de verdad sucede. Código. Builds. Deployments.

Las preguntas aquí son **brutalmente específicas**:

"¿Qué porcentaje de builds se detienen automáticamente si hay vulnerabilidad crítica detectada por SAST?"

No es: "¿Hacemos SAST?"

Es: "¿SAST te *obliga* a hacer algo? ¿O es recomendación que el Developer ignora?"

Porque ese diferencial—recomendación vs. requerimiento—es donde vive la diferencia entre **Nivel 1 (ad-hoc) y Nivel 2+ (estructurado)**.

Módulo 5: Verificación (Testing que Significa Algo)

Verificación es verificación. ¿Probaste que es seguro?

Pero la pregunta profunda es: **¿Lo probaste o solo lo miraste?**

Y si lo probaste, ¿encontraste algo? Porque si Verification (testing de seguridad) nunca encuentra vulnerabilidades, es porque:

1. Tu código es perfecto (probabilidad: < 1%), o
2. Tu testing no es riguroso (probabilidad: ~99%)

La encuesta te fuerza a confrontar eso.

Módulo 6: Operaciones (El Silencio Ruidoso)

Operations es silenciosa. Por eso sorprende que típicamente puntúa más alto que otras funciones en benchmarks globales.

¿Por qué?

Porque cuando (no si, *cuando*) un incidente ocurre, Operaciones **tiene que responder**. No hay opción de "haremos mejor próxima vez."

Entonces Operaciones construye capacidad. Porque es existencial.

La encuesta reconoce eso. Y pregunta: ¿Qué tan maduro es tu MTTD (tiempo para detectar)? ¿Tu MTTR (tiempo para reparar)?

Métricas reales. No aspiracionales.

Módulo 7: Análisis de Vulnerabilidades (Precisión en el Caos)

Análisis de vulnerabilidades es donde mucha sofisticación se esconde.

Porque no es solo "encontrar bugs". Es priorizar bugs en contexto.

Una vulnerabilidad CVSS 9.0 podría no importar si:

- Solo afecta sistemas internos
- No hay datos sensibles
- O el componente nunca se ejecuta en tu ambiente

Pero una vulnerabilidad CVSS 5.0 que **sí es explotable, sí está expuesta, sí afecta datos críticos**—esa es la que cierra el negocio.

La encuesta pregunta: ¿Entiendes esa diferencia? ¿La aplicas?

Módulo 8: SIEM (El Observador Silencioso)

SIEM es donde muchas organizaciones **gastan dinero creyendo que compran madurez**.

"Tenemos Splunk. Debe ser L4, ¿no?"

No. Splunk es una herramienta. La madurez es: ¿Qué haces con los datos que recibe?

- ¿Miraste una vez? L0.
- ¿Lo miras regularmente? L1.
- ¿Tienes alertas? L2.
- ¿Tus alertas actuales generan 1000 falsos positivos/día? L1.5 (peor que antes).
- ¿Las alertas que generan investigación valiosa? L3.
- ¿Parte de la respuesta es automática? L4.

SIEM es donde la ironía se vuelve especialmente evidente.

Módulo 9: Capacitación (El Factor Humano Incómodo)

Capacitación en seguridad es donde la mayoría de organizaciones hace teatro.

"Completamos e-learning obligatorio."

¿Y qué pasó?

"Los empleados olvidaron el 80% en dos semanas."

¿Se midió cambio de comportamiento?

"Ehhhhh... no realmente."

La encuesta no te juzga. Te pregunta: ¿Realmente educas o solo cumples requisito?

Porque eso—la diferencia entre cumplimiento y educación—es donde vive la madurez real.

Módulo 10: Cumplimiento Normativo (El Reloj Que Avanza)

NIS2 tiene plazo (Octubre 2024, ya pasado para muchos). CRA tiene plazo (Diciembre 2024). DORA, GDPR, ENS...

La encuesta cierra con preguntas sobre **alineación normativa**.

No porque el cumplimiento sea el objetivo. Sino porque es **medida externa de urgencia**.

Si decimos "necesitamos L1.8 en SAMM para cumplir NIS2", eso concentra la mente. Da dirección.

ACTO VI: METÁFORA DE LA ORQUESTA

Imagina que la seguridad de software es una orquesta.

- **Gobernanza:** El director. Establece tempo, visión, interpretación.
- **Diseño:** Los compositores y arreglistas. Decide qué notas suenan.
- **Implementation:** Los músicos. Toca los instrumentos. Practican.
- **Verificación:** Los auditores acústicos. Escuchan y dicen "ese violín está desafinado."
- **Operaciones:** Los técnicos de sonido. Aseguran que el sonido llegue al público.
- **SIEM:** El sistema de grabación. Captura todo. Permite reescucha y análisis.
- **Capacitación:** El entrenamiento de los músicos. La disciplina. El conocimiento del instrumento.

Cuando la orquesta es L0, cada instrumento toca lo que quiere. Sonido caótico.

Cuando es L1, hay partitura, pero los músicos no siempre la siguen.

Cuando es L2, hay partitura, disciplina, estructura.

Cuando es L3, además hay métricas: "¿Qué secciones entonaron mal? ¿Cuántas veces?" Y mejoran.

Cuando es L4, la orquesta se adapta en tiempo real. El director ajusta tempo basándose en acústica. Los músicos anticipan cómo va a sonar.

SAMM es música. La encuesta pregunta: ¿Qué tan buena es tu orquesta?

ACTO VII: CÓMO LEER LAS RESPUESTAS (HERMENÉUTICA DE LA CIBERSEGURIDAD)

Cuándo Alguien Responde "No Tengo Suficiente Visibilidad"

Eso **no es debilidad en la encuesta**. Es **debilidad identificada en la organización**.

Significa: "No comunicamos suficientemente qué está pasando en esta función."

Eso es dato valioso. Es como un médico que dice "No puedo diagnosticar la enfermedad porque no veo radiografías."

El problema no es el médico. Es el sistema de diagnóstico.

Cuándo Role A Dice L3 y Role B Dice L1

No te sorprendas. Es *esperado*.

- Role A ve su parte del sistema. Ve sofisticación (porque trabaja allí).
- Role B ve el sistema completo. Ve grietas (porque las ve todas).

Ambos ven verdad. Verdades diferentes.

Tu trabajo es reconciliar: "Sí, Implementation tiene algunos elementos sofisticados. Pero Design es débil, lo que significa que Implementation es sofisticado *pero no enfocado*."

Cuándo Todos Dicen Prácticamente el Mismo Número

Eso es raro y hermoso.

Significa que esa práctica está tan enraizada en la organización que *trasciende silos*.

Cuando todos dicen "Incident Response está en L2.5", significa que **realmente** hay capability en incident response. No es ilusión.

Eso es donde puedes confiar. Y desde allí, escalar.

EPÍLOGO: EL PROPÓSITO FINAL

Esta Encuesta Integral de Ciberseguridad, con su tono irónico, su estructura literaria y su intención propositiva, no busca:

- ✗ Decirte que eres mejor/peor que otros
- ✗ Colocarte en una jerarquía de industria
- ✗ Generarte ansiedad existencial sobre tu postura de seguridad

Busca, en cambio:

- ✓ **Crear espejo honesto:** Mostrarte cómo diferentes partes de tu organización ven la realidad
- ✓ **Identificar fricción como oportunidad:** Convertir desalineaciones en iniciativas
- ✓ **Proponer camino claro:** De donde eres a donde necesitas ser
- ✓ **Reconocer that complexity es normal:** No hay respuestas "correctas"; hay respuestas contextuales

La ciberseguridad empresarial es **fundamentalmente política, cultural e interpretativa**.

No es un problema que resuelves. Es un proceso que mejoras. Continuamente.

Esta encuesta es **herramienta para esa mejora continua**. No más, no menos.

REFLEXIÓN FINAL

En el fondo, la pregunta que motivó esta encuesta fue simple:

"¿Cómo evaluamos ciberseguridad de forma honesta, incluyendo la duda, la ironía y la humildad?"

Porque honestamente, cualquier persona que te dice que su ciberseguridad está en L4 (Optimizado) me preocupa.

Significa que o bien:

1. No entiende el significado de "optimizado" (improbable)
2. Ha dejado de mirar críticamente lo que hace (más probable)

En cambio, alguien que dice "Estamos en L2 en Design y L1.5 en Gobernanza porque comunicamos mal la estrategia"—*esa persona entiende*.

Ha visto la grieta entre proclama y realidad.

Ha aceptado la ironía. Y está lista para cambiar.

Eso es madurez real. Y es lo que esta encuesta intenta medir.

APÉNDICE: VOCABULARIO Y FRASEOLOGÍA

Términos Que Aparecen Intencionalmente de Forma Literaria

Término	Uso en Encuesta	Significado Profundo
Threat Model	"¿Existen documentados?"	¿Anticipamos o esperamos? ¿Somos proactivos?
Gate	"¿Security gates detienen builds?"	¿La política tiene dientes? ¿O es recomendación ignorada?
MTTD / MTTR	"Tiempo promedio..."	¿Qué tan rápido vemos el dolor? ¿Qué tan rápido lo curamos?
Cobertura	"¿Qué porcentaje..."	¿Es excepción o regla? ¿Es norma de todos o hobby de algunos?
Sofisticación	"¿Qué tan avanzado..."	¿Puedo confiar en esto? ¿O es frágil?
Rol	"¿Cuál es su rol principal?"	¿De dónde ves el mundo? ¿Qué puntos ciegos tienes?
Confianza	Meta-pregunta	¿Cuánto sabes realmente? ¿O adivinas?

Fin del documento.

Que disfrute la lectura. Y que las respuestas te sorprendan, desafíen, y ultimately, guíen hacia mejora.